1. Company Overview

MedBridge Health, Inc. is a fictional healthcare company based in San Francisco, California, the company provides telehealth services, including virtual primary care and behavioral health appointments. The company has over 50 employees and serves approximately 40,000 patients across six different U.S. states.

MedBridge Health uses cloud-based technology to support its daily operations, including AWS for hosting applications and storing patient information, Okta for identity and access management, and Google Workspace for business communication.

Since the company handles sensitive patient information, including Protected Health Information (PHI) and Personally Identifiable Information (PII), protecting this data is an important part of its cybersecurity and compliance responsibilities.

The company must follow applicable healthcare regulations, including HIPAA and HITECH, while working toward its goal of obtaining a SOC 2 Type II report within 12 months.

1.1 Company Information

Category	Details
Company Name	MedBridge Health, Inc.
Headquarters	San Francisco, California
Industry	Healthcare / Telehealth
Employees	50
Active Patients	Approximately 40,000
Locations Served	Six U.S. states
Annual Recurring Revenue	Approximately $8 million
Cloud Infrastructure	Amazon Web Services (AWS)
Identity Management	Okta
Business Communication	Google Workspace
Security Leadership	Part-time vCISO and IT Manager
Compliance Considerations	HIPAA, HITECH, applicable state privacy laws
Business Objective	SOC 2 Type II report within 12 months

2. Organizational Structure and Security Responsibilities

MedBridge Health, Inc. has 50 employees working across different departments, including clinical services, engineering, operations, sales, finance, and executive leadership.

Since MedBridge Health is a small healthcare company, it doesn't have a dedicated cybersecurity department. Instead, cybersecurity and compliance responsibilities are shared between the IT Manager, a part-time virtual **Chief Information Security Officer (vCISO**), and other department leaders.

Each department has its own responsibilities when it comes to protecting patient information, managing security risks, and helping the company meet its compliance requirements.

2.1 Employee Distribution

Department	Employees
Clinical Services	18
Engineering	12
Operations & Support	8
Sales & Marketing	6
Finance & Human Resources	4
Executive Leadership	2
Total	**50**

2.2 Security Roles and Responsibilities

Role	Responsibilities
Chief Executive Officer (CEO)	Approves security policies, provides leadership oversight, and accepts high-level business risks.
Chief Technology Officer (CTO)	Manages technical security risks, AWS infrastructure, applications, and engineering security controls.
Virtual Chief Information Security Officer (vCISO)	Oversees the cybersecurity program, develops security policies, and coordinates risk assessments and compliance activities.
IT Manager	Manages employee devices, user accounts, network security, backups, and third-party technology onboarding.
Privacy Officer (COO)	Oversees HIPAA privacy compliance, protects patient information, and coordinates breach notification responsibilities.
HR Manager	Manages employee onboarding, offboarding, and security awareness training records.

2.3 Security Governance

MedBridge Health uses a shared approach to cybersecurity governance because it does not have a full-time security team. The vCISO helps develop and manage the security program, while the IT Manager handles day-to-day technical security responsibilities.

The CEO provides oversight and approves major security decisions. The CTO is responsible for managing technical risks, while the Privacy Officer focuses on protecting patient information and meeting HIPAA requirements.

Having clearly defined responsibilities helps the company improve accountability, identify security gaps, and make sure cybersecurity risks are handled by the appropriate people.

3. Data Classification

MedBridge Health, Inc. handles different types of information as part of its daily operations, including patient medical records, employee information, financial records, and application source code.

Since the company provides telehealth services, protecting patient information is one of its main security priorities. MedBridge Health uses a data classification system to identify how sensitive information is and how it determines what security controls should be used to protect it.

3.1 Data Classification Levels

Classification	Description
Restricted	Highly sensitive information that requires the strongest security protections, including patient health records and personally identifiable information (PII).
Confidential	Sensitive business or employee information that should only be accessible to authorized personnel ONLY!
Internal	Information used for daily business operations that is not intended for public access.
Public	Information approved for public viewing, such as website content and marketing materials.

3.2 Data Inventory

Data Type	Classification	Storage Location
Protected Health Information (PHI)	Restricted	Electronic Health Records (EHR), AWS database
Patient Personally Identifiable Information (PII)	Restricted	EHR, billing system
Payment Information (Tokenized)	Restricted	Stripe
Employee Personal Information	Confidential	Gusto HR and payroll
Application Source Code	Confidential	GitHub
Financial Records	Confidential	Google Drive, QuickBooks
Marketing Materials	Public	Webflow

3.3 Data Protection Requirements

MedBridge Health needs to protect sensitive information from unauthorized access, accidental disclosure, and data breaches.

The following security controls are my recommendations to help protect the company and patient information:

- **Encryption:** Protects sensitive information while it is stored and transmitted.
- **Access Control:** Limit access to information based on employee roles and job responsibilities.
- **Multi-Factor Authentication (MFA):** Require additional verification when employees access sensitive systems.
- **Audit Logging:** Monitor access to systems that store or process patient information.
- **Data Minimization:** Only collect and share the information necessary for business operations.
- **Secure Disposal:** Properly delete or dispose of sensitive information when it is no longer needed, subject to retention requirements.

These controls help reduce the risk of unauthorized access to sensitive information and support MedBridge Health's security and compliance goals.

4. IT Infrastructure and Critical Assets

MedBridge Health uses cloud infrastructure, healthcare applications, employee devices, and third-party services to support its daily operations.

The company's main infrastructure is hosted in Amazon Web Services (AWS), which supports its patient applications, databases, and storage systems. MedBridge Health also uses Okta for identity and access management, Google Workspace for business communication, and other services to support employees and healthcare providers.

Identifying these systems is important because it helps the company understand which assets need to be protected, who is responsible for managing them, and what security risks could affect business operations.

4.1 Critical IT Assets

Asset	Business Owner	Criticality
AWS Production Environment	CTO	Critical
Electronic Health Records (EHR)	CTO	Critical
Patient Web and Mobile Application	CTO	Critical
Clinician Portal	CTO	Critical
Okta Identity Platform	IT Manager	Critical
Google Workspace	IT Manager	High
Employee Laptops	IT Manager	High
Office Network	IT Manager	High
GitHub Repositories	CTO	High
Zoom for Healthcare	CTO	High
Twilio Messaging	Privacy Officer	High
Zendesk Support	Privacy Officer	High
Gusto Payroll	HR Manager	High
Stripe Payments	CTO	High
Slack	IT Manager	Medium

4.2 Cloud Infrastructure

MedBridge Health uses AWS to host its production environment, including EC2 instances for applications, Amazon RDS PostgreSQL for database management, and Amazon S3 for cloud storage.

Since these systems support patient information and healthcare services, they are considered critical assets. Unauthorized access, system misconfigurations, or service outages could affect patient privacy and the availability of healthcare services.

4.3 Identity and Endpoint Management

MedBridge Health uses Okta to manage employee authentication through Single Sign-On (SSO) and Multi-Factor Authentication (MFA).

The company has approximately 50 employee laptops, including 35 MacBooks and 15 Windows devices. These devices are managed through Jamf and Microsoft Intune.

Employee devices and user accounts must be properly managed to reduce the risk of unauthorized access, malware infections, and data exposure.

4.4 Asset Management Challenges

MedBridge Health currently has several simulated asset management weaknesses:

- The company does not maintain a complete, formal asset inventory.
- Its existing laptop inventory spreadsheet has not been updated in approximately six months.
- Some employee access removal processes are delayed after offboarding.
- The company has limited visibility into security events because collected logs are not regularly reviewed.

These weaknesses could make it difficult to identify vulnerable systems, manage user access, and detect potential cybersecurity threats.

Improving asset inventory accuracy, access management, and security monitoring will help MedBridge Health strengthen its overall cybersecurity program.

5. Third-Party Vendors

MedBridge Health, Inc. relies on third-party vendors to support its healthcare services, cloud infrastructure, communication systems, and daily business operations.

Since some vendors may have access to Protected Health Information (PHI) and other sensitive data, MedBridge Health needs to make sure these vendors follow appropriate security and privacy requirements.

Under HIPAA, vendors that qualify as business associates generally require a signed Business Associate Agreement (BAA) before handling PHI on behalf of MedBridge Health.

5.1 Third-Party Vendor Inventory

Vendor	Service Provided	Data Access	BAA Required
Amazon Web Services (AWS)	Cloud hosting and storage	PHI	Yes
Zoom for Healthcare	Virtual healthcare appointments	PHI	Yes
Stripe	Payment processing	Payment information	No*
Twilio	Appointment reminders	Patient PII and appointment details	Yes
Google Workspace	Email and document management	Possible PHI	Yes
Gusto	Employee payroll and HR	Employee PII	No*
Okta	Identity and access management	Employee identities	No*
Zendesk	Patient support services	Possible PHI	Yes

Business Associate Agreement (BAA) requirements depend on the vendor's actual services and whether it creates, receives, maintains, or transmits PHI on behalf of MedBridge Health.

5.2 Third-Party Security Risks

Working with external vendors introduces security and compliance risks that MedBridge Health must manage.

Some potential risks include:

- **Unauthorized Access:** A compromised vendor account could expose sensitive patient or company information.
- **Data Breaches:** A security incident involving a vendor could affect MedBridge Health's patient information.
- **Missing Business Associate Agreements:** Vendors handling PHI without required BAAs could create HIPAA compliance issues.
- **Insufficient Vendor Monitoring:** Without regular assessments, the company may not identify vendor security weaknesses.
- **Service Disruptions:** Vendor outages could affect healthcare appointments and business operations.

5.3 Identified Vendor Compliance Gaps

Based on the fictional company scenario, MedBridge Health currently has two known vendor compliance gaps:

1. **Twilio:** No signed Business Associate Agreement is on file, even though the simulated appointment reminder workflow may involve PHI.
2. **Zendesk:** No signed Business Associate Agreement is on file, despite patient support tickets potentially containing PHI.

These gaps could expose MedBridge Health to compliance violations and increase the risk of unauthorized patient information disclosure.

5.4 Recommended Security Improvements

To improve third-party risk management, MedBridge Health should:

1. Review existing vendor contracts and obtain required BAAs before permitting PHI processing.
2. Conduct security and privacy assessments before onboarding new vendors.
3. Maintain an updated vendor inventory that identifies services, data access, and responsible owners.
4. Review vendor security documentation and compliance reports when available.
5. Establish a process for periodically reassessing vendors and tracking identified security risks.

Implementing these steps will help MedBridge Health reduce third-party security risks and strengthen its overall compliance program.

6. Known Security Weaknesses and GRC Findings

After reviewing MedBridge Health's security environment, I identified several weaknesses that could put patient information and company systems at risk.

Since MedBridge Health does not have a dedicated cybersecurity team, some security processes are not documented or regularly reviewed. This could make it harder for the company to detect security threats, respond to incidents, and protect sensitive information.

The following weaknesses are based on the fictional company scenario and will be used for the risk assessment later in this project.

6.1 Identified Security Weaknesses

ID	Security Weakness	Potential Risk
SW-01	Outdated asset inventory	Untracked devices and systems could remain vulnerable or improperly secured.
SW-02	Limited security awareness training	Employees may be more likely to fall for phishing attacks or mishandle sensitive information.
SW-03	Untested backup restoration	MedBridge Health may be unable to recover important systems and patient records after a ransomware attack or system failure.
SW-04	No documented incident response plan	Security incidents may not be handled quickly or consistently, causing delays in investigation and breach notification.
SW-05	Missing Business Associate Agreements	Twilio and Zendesk may process patient information without required HIPAA contractual protections.
SW-06	Shared firewall administrator account	Multiple employees using one administrator account makes it difficult to track changes and identify unauthorized activity.
SW-07	Security logs are not regularly reviewed	Suspicious activity and potential cyberattacks may go undetected.
SW-08	Delayed employee offboarding	Former employees may retain access to company systems and sensitive information after leaving the organization.

6.2 Potential Business and Compliance Impact

These security weaknesses could cause problems for MedBridge Health if they are not addressed.
Some of the main concerns include:

- **Patient Privacy:** Sensitive patient information could be exposed if an unauthorized person gains access to company systems.
- **Regulatory Compliance:** Missing vendor agreements and weak security practices could lead to HIPAA compliance issues.
- **Business Operations:** A ransomware attack, system outage, or failed backup could interrupt healthcare services.
- **Financial Impact:** A security incident could cost the company money through recovery expenses, legal fees, and potential penalties.
- **Reputation:** A data breach could damage the company's reputation and cause patients to lose trust in its services.

6.3 Recommended Security Improvements

Based on the weaknesses identified, I recommend that MedBridge Health focus on improving the following areas:

1. Keep an updated inventory of company devices, applications, and cloud services.
2. Provide regular security awareness training to help employees recognize phishing attacks and other security threats.
3. Test backups regularly to make sure important systems and patient records can be recovered.
4. Create a documented incident response plan so employees know what to do when a security incident occurs.
5. Review vendor agreements and make sure required Business Associate Agreements are signed before vendors handle PHI.
6. Remove shared administrator accounts and assign individual accounts to improve accountability.
7. Review security logs regularly to identify suspicious activity and potential threats.
8. Improve the employee offboarding process to make sure former employees no longer have access to company systems.

6.4 GRC Assessment Summary

Based on the findings, MedBridge Health has several areas where its cybersecurity program could be improved. The main concerns involve asset management, access control, incident response, security monitoring, and third-party vendors.

Addressing these weaknesses would help the company better protect patient information, reduce cybersecurity risks, and work toward meeting its compliance requirements.

I'll use these findings in the next GRC projects to build a risk register, develop security policies, and assess MedBridge Health against the NIST Cybersecurity Framework (CSF) 2.0.